COLORADO
Information Security
Governor's Office of Information Technology

CISP-002: Incident Response Policy

Document ID	CISP-002
Title	Incident Response Policy
Executive Sponsor	Jill Fraser, Chief Information Security Officer
Issuing Authority	Governor's Office of Information Technology (OIT)
Applies to	All public agencies as defined by C.R.S. 24-37.5-102(26). All contracted parties must comply with these requirements.
Instrument Type	Policy
Version	3.0
Effective Date	07/01/2026
Last Updated	03/09/2026

1. Purpose

This policy supports the State of Colorado Chief Information Security Officer (CISO) in achieving the requirements of the Colorado Information Security Act (C.R.S. 24-37.5-401, et seq.). It governs public agency incident response and continuity planning and implementation.

2. Applicability

This policy applies to all public agencies as defined by C.R.S. 24-37.5-102(26). All contracted parties must comply with these requirements.

3. Defined Terms

All CISP-specific terms are defined in the CISP Glossary unless otherwise defined in this policy.

4. Policy

All state IT resources and state data are the sole property of the State of Colorado, and applicable statutes, policies, and technical standards govern their use. Public agencies must implement incident response, continuity management, and contingency planning in accordance with this policy.

5. Safeguards

Incident Response

The agency, in coordination with the Office of Information Technology, must establish, maintain and document an agency-level incident response plan. At a minimum, the plan must:

- Designate personnel for incident response and recovery.

- Establish, maintain, and regularly verify contact information of designated incident response and recovery personnel, and distribute it to OIT.
- Establish, maintain, and document a process for reporting security incidents.
- Establish, maintain, and document an incident response process.
- Plan, conduct, and document routine incident response exercises.

Consolidated agencies must notify the state CISO if an incident involves a state system, network, IT resources, or state data. Incidents must be reported to the OIT Service Desk at 303-239-HELP (4357) or through the ServiceHub Customer Portal. OIT will communicate OIT-discovered incidents to affected agencies.

Logging and Monitoring

The Office of Information Technology must establish, maintain, and document a logging and monitoring management process that serves to detect security incidents and events, and to support investigation of security breaches, policy violations, and regulatory compliance, where possible. OIT, in coordination with the agency, must:

- Develop and maintain processes that increase the likelihood of identifying security-relevant events early.
- Define and implement additional logging functions where necessary.
- Regularly review and update logging requirements.
- Provide logs to agencies upon request.

Scope of Logging and Monitoring

Logging and monitoring management documentation must state that all systems, networks, and applications are subject to logging and monitoring activities.

Types of Data to be Logged

Standard operating procedures or process documentation must identify what events from the following will be logged:

- Authentication attempts.
- Access to resources.
- System events, including but not limited to operating system, application, database and network events.
- Network traffic.
- Security-related audit events.
- Changes to system configurations.
- Sessions.

Log Retention

The technology provider should allocate and retain log storage for 90 days for all logs, and must retain logs longer where regulatory or legal compliance requires.

Access to Logs

The technology provider must restrict access to logs to individuals with a need-to-know designation.

Protection of Log Data

Log data must be stored in a protected environment or secured within the technology solution.

Monitoring for Security Events

The logging and monitoring management process must require daily monitoring for security events.

Respond to Logging and Monitoring Failures

The information technology security provider must respond to logging and monitoring failures.

Time Clock Synchronization

The technology provider must synchronize internal information system clocks with an authoritative time source to ensure log integrity and correlation.

Continuity Planning

OIT's Continuity Program adheres to NIST standards and the Colorado Information Security Act, and follows guidelines from the Division of Homeland Security and Emergency Management (DHSEM) within the Colorado Department of Public Safety.

Alternate Communications

The technology provider should include alternative communications protocols in case primary protocols are disrupted or insecure, in support of continuity of operations.

Information System Backups

The technology provider must ensure information system backups by regularly verifying, documenting, monitoring, and testing backups.

6. Compliance

Failure of users to comply with this policy may result in, as applicable:

- Loss of federal grant funding, fines and penalties.
- Agency-level sanctions regarding state IT resources: restriction, deactivation, or suspension of the user's account, project, or system, or termination of employment.
- Termination of contract or assignment for temporary workers, interns, volunteers, contractors, or vendors who violate this policy.

Non-consolidated agencies must have appropriate policies and/or procedures to ensure compliance with this policy and all other Colorado Information Security Policies.

7. Exceptions

Any exceptions to this policy must be documented, justified, and approved in advance of implementation. Requestors must submit a Secure Configuration Exception Request.

8. References

- Colorado Information Security Act (C.R.S. 24-37.5-401, et seq.)

- Colorado Open Records Act (C.R.S. § 24-72-200.1, et seq.)
- State of Colorado Universal Policies
- Secure Configuration Exception Request in ServiceHub
- US Government ITAR country list
- Password & Account Management Requirements Chart
- Colorado Information Security Policy - CISP Information Security Glossary